**KARTIKA CYBER HACKATHON 2026**

Pusat Siber Angkatan Darat (PUSSIBERAD) × CODEPOLITAN

---

# POLARIS

## Peringatan Dini Berbasis Deception untuk Jaringan IT/OT dengan False Positive Rendah secara Desain

Proposal Solusi

Kategori 02 — Defensive Shield (Penangkalan)

---

**MUH SYAHRIR HAMDANI**

Peserta Individu

25 Oktober 2026

Versi 1.0

Dokumen ini disusun untuk Babak Penyisihan Online.

Batas akhir submission: 15 November 2026.

## Abstrak

Pertahanan siber satuan menghadapi dua tekanan yang saling memperkuat: penyusup yang telah melewati perimeter bergerak di dalam jaringan, sementara sistem deteksi berbasis anomali menghasilkan alert dalam jumlah besar dengan false positive yang tinggi. Pada jaringan TNI AD yang sebagian terisolasi dan menggabungkan IT dengan OT/ICS, solusi yang bergantung pada cloud atau threat intelligence eksternal juga sulit diterapkan. Proposal ini merancang POLARIS, sistem peringatan dini berbasis deception yang menanam umpan—decoy port, honeytoken file, canary credential, honeytoken URL, web decoy, dan decoy OT/ICS—yang secara desain tidak dilalui operasi normal. Interaksi dengan umpan diperlakukan sebagai sinyal berkeyakinan tinggi, lalu dikorelasikan menjadi incident, dipetakan ke MITRE ATT&CK (Enterprise dan ICS), dan diteruskan ke dashboard serta kanal alert. POLARIS dirancang on-prem, dapat berjalan di jaringan air-gap, dan menyediakan bukti yang siap forensik. Penulis menekankan batas klaim: false positive tidak dijamin nol karena backup, pemindai kerentanan, dan kesalahan administrator dapat menyentuh umpan; karena itu proposal ini menyertakan tier kepercayaan, allowlist operasional, dan rencana evaluasi terkontrol. Dokumen ini merupakan proposal solusi dan rencana pengembangan, bukan laporan hasil pengukuran. Target yang akan diuji mencakup latensi deteksi, kelengkapan bukti, jumlah false positive pada beban kerja wajar, dan akurasi korelasi.

*Kata kunci:* deception defense, honeytoken, deteksi penyusupan, IT/OT, MITRE ATT&CK, keamanan siber

## Abstract

Defensive cyber operations face two reinforcing pressures: intruders who have crossed the perimeter move laterally inside the network, while anomaly-based detection systems produce large volumes of alerts with high false-positive rates. In Indonesian Army networks that are partly isolated and combine IT with OT/ICS, solutions depending on cloud services or external threat intelligence are also difficult to deploy. This proposal designs POLARIS, a deception-based early-warning system that plants decoys—decoy ports, honeytoken files, canary credentials, honeytoken URLs, web decoys, and OT/ICS decoys—that normal operations are not expected to touch. Interaction with a decoy is treated as a high-confidence signal, correlated into an incident, mapped to MITRE ATT&CK (Enterprise and ICS), and delivered to a dashboard and alert channels. POLARIS is designed to run on-premises, operate in air-gapped networks, and preserve forensics-ready evidence. The author states the claim boundary explicitly: false positives are not guaranteed to be zero because backups, vulnerability scanners, and administrator mistakes may touch a decoy; the proposal therefore includes confidence tiers, operational allowlists, and a controlled evaluation plan. This document is a solution proposal and develop-

ment plan, not a report of measured results. The targets to be tested include detection latency, evidence completeness, false-positive count under a benign workload, and correlation accuracy.

*Keywords:* deception defense, honeytoken, intrusion detection, IT/OT, MITRE ATT&CK, cybersecurity

# Daftar Isi

**Abstrak** **1**

**Abstract** **1**

**Daftar Singkatan** **5**

**Ringkasan Eksekutif** **5**

**1 Pendahuluan** **6**
1.1 Latar Belakang . . . 6
1.2 Rumusan Masalah . . . 7
1.3 Tujuan dan Sasaran . . . 7
1.4 Ruang Lingkup dan Batas Awal . . . 7
1.5 Kontribusi . . . 8

**2 Tinjauan Pustaka dan Dasar Konsep** **8**
2.1 Deception Defense dan Honeypot . . . 8
2.2 Deteksi Deterministik dan Batasnya . . . 8
2.3 MITRE ATT&CK sebagai Bahasa Pemetaan . . . 9
2.4 Posisi POLARIS . . . 9

**3 Solusi yang Diusulkan** **9**
3.1 Gambaran Umum . . . 10
3.2 Prinsip Desain . . . 10
3.3 Komponen Sistem . . . 10
3.4 Alur Kerja . . . 11
3.5 Taksonomi Umpan dan Tier Kepercayaan . . . 11
3.6 Deteksi, Korelasi, dan Severity . . . 12
3.7 Pemetaan MITRE ATT&CK . . . 12
3.8 Dukungan OT/ICS . . . 13
3.9 AI Summarizer dengan Batas Peran . . . 13

**4 Arsitektur Teknis** **14**
4.1 Agent . . . 14
4.2 Collector dan Detection Engine . . . 15
4.3 Dashboard dan Kanal Alert . . . 15
4.4 Model Deployment . . . 15
4.5 Keamanan Sistem . . . 15
4.6 Kinerja dan Skalabilitas . . . 16

**5 Metode Pengembangan dan Evaluasi** **16**
5.1 Pendekatan Pengembangan . . . 16
5.2 Lingkungan Uji . . . 16
5.3 Skenario Uji . . . 16
5.4 Metrik Evaluasi . . . 17
5.5 Prosedur Analisis . . . 17
5.6 Etika dan Keamanan Pengujian . . . 17

**6 Relevansi dan Manfaat untuk TNI AD** **17**
6.1 Kebutuhan IT/OT . . . 17
6.2 Kesesuaian dengan Jaringan Air-Gap . . . 18

6.3 Pengurangan Beban Analis . . . . . 18
6.4 Kesiapan Forensik . . . . . 18
6.5 Roadmap Adopsi . . . . . 18

**7 Kelayakan Implementasi** **18**
7.1 Stack dan Dependensi . . . . . 18
7.2 Instalasi dan Operasi . . . . . 18
7.3 Sumber Daya . . . . . 19
7.4 Risiko Implementasi . . . . . 19

**8 Inovasi Teknis** **19**

**9 Roadmap dan Rencana Kerja** **19**

**10 Kesesuaian dengan Kriteria Penilaian** **20**

**11 Batasan dan Ancaman Validitas** **20**
11.1 Sumber False Positive . . . . . 20
11.2 Keterbatasan Lain . . . . . 20

**12 Penutup** **21**

**Pernyataan Orisinalitas dan Penggunaan Alat Bantu** **22**

**Daftar Pustaka** **23**

**A Pemetaan MITRE ATT&CK** **24**

**B Daftar Periksa Penempatan Umpan** **24**

## Daftar Singkatan

| Singkatan | Kepanjangan |
|---|---|
| ATT&CK | Adversarial Tactics, Techniques, and Common Knowledge |
| EDR | Endpoint Detection and Response |
| HMI | Human–Machine Interface |
| ICS | Industrial Control System |
| IDS | Intrusion Detection System |
| IPS | Intrusion Prevention System |
| IT | Information Technology |
| MITRE | The MITRE Corporation |
| MVP | Minimum Viable Product |
| OT | Operational Technology |
| PLC | Programmable Logic Controller |
| SCADA | Supervisory Control and Data Acquisition |
| SIEM | Security Information and Event Management |
| SOC | Security Operations Center |
| SOAR | Security Orchestration, Automation, and Response |
| TTP | Tactics, Techniques, and Procedures |

## Ringkasan Eksekutif

POLARIS adalah sistem peringatan dini yang membalik cara kerja deteksi konvensional. Alih-alih menebak mana lalu lintas yang “anomali”, POLARIS menanam umpan yang tidak memiliki alasan sah untuk disentuh. Koneksi ke port umpan, pembacaan berkas umpan, penggunaan kredensial umpan, atau interaksi dengan perangkat OT palsu dicatat sebagai event. Event dari satu sumber kemudian dikorelasikan menjadi satu incident yang menjelaskan apa yang terjadi, teknik MITRE apa yang terindikasi, dan bukti apa yang tersimpan.

Empat hal membedakan proposal ini dari sekadar honeypot tunggal. Pertama, umpan bersifat multi-vektor: port, berkas, kredensial, URL, jalur web, dan protokol OT. Kedua, event tidak dikirim sebagai alert mentah, tetapi diolah menjadi incident dengan tingkat keparahan dan konteks. Ketiga, sistem dirancang untuk jaringan IT dan OT sekaligus, termasuk decoy Modbus/TCP dan HMI. Keempat, seluruh komponen dapat berjalan on-prem di jaringan air-gap, tanpa ketergantungan cloud.

Penulis tidak mengklaim false positive nol. Umpan dapat tersentuh oleh backup, pemindai kerentanan, alat konfigurasi, atau kekeliruan administrator. Karena itu, proposal ini memakai tier kepercayaan, allowlist operasional, dan evaluasi dengan beban kerja wajar. Klaim yang diajukan lebih sempit dan dapat diuji: POLARIS memberikan sinyal berkeyakinan tinggi, menyatukan event menjadi incident yang dapat ditindaklanjuti, dan menyimpan bukti sejak detik

pertama.

Keluaran yang akan diserahkan meliputi agent Go, collector dan detection engine berbasis FastAPI, dashboard live, kanal alert Telegram/webhook, installer satu baris, dokumentasi teknis, video demo, dan slide presentasi. Purwarupa diuji di laboratorium terisolasi dengan skenario pemindaian, brute force, akses honeytoken, dan interaksi decoy OT. Dokumen ini menjelaskan rancangan, batas klaim, rencana evaluasi, dan langkah pengembangan sampai 15 November 2026.

# 1. Pendahuluan

## 1.1 Latar Belakang

Jaringan satuan TNI AD tidak lagi berupa kumpulan server yang berdiri sendiri. Di banyak titik, jaringan information technology (IT) bertemu dengan operational technology (OT): SCADA, PLC, HMI, dan perangkat lapangan yang mengendalikan proses fisik. Sebagian jaringan beroperasi terisolasi atau air-gap, sebagian lain memiliki jembatan terbatas ke jaringan administratif. Kondisi ini menciptakan dua persoalan sekaligus. Penyusup yang berhasil melewati perimeter dapat bergerak di dalam jaringan tanpa terlihat oleh perangkat perimeter, sementara sistem deteksi yang mencoba membedakan "normal" dan "mencurigakan" menghasilkan alert dalam jumlah besar yang sebagian besar bukan serangan.

Pendekatan anomaly detection bergantung pada baseline. Ketika baseline berubah karena penambahan server, pembaruan aplikasi, atau perubahan jam kerja, ambang deteksi perlu disesuaikan. Analis kemudian dihadapkan pada ratusan atau ribuan alert, dan alert yang benar-benar penting tenggelam. Masalah ini bukan sekadar ketidaknyamanan operasional. Ia memperlambat respons, menghabiskan waktu analis, dan membuat organisasi cenderung mengabaikan sinyal yang lemah.

Deception defense menawarkan jalan lain. Alih-alih menebak niat pengguna, sistem menempatkan umpan yang tidak memiliki fungsi sah. Koneksi ke port umpan, pembacaan berkas umpan, atau penggunaan kredensial umpan adalah peristiwa yang dapat dicatat tanpa terlebih dahulu membangun model perilaku normal. Pendekatan ini bukan hal baru dalam literatur keamanan (Spitzner, 2002; Provos & Holz, 2007; Han et al., 2018). Yang masih jarang adalah implementasi yang menyatukan beberapa jenis umpan, mengolah event menjadi incident, memetakan teknik penyerang, dan menyiapkan seluruh komponen agar dapat berjalan di jaringan tertutup.

Kartika Cyber Hackathon 2026 memberi ruang untuk menguji gagasan tersebut. Kompetisi yang diselenggarakan Pusat Siber Angkatan Darat (PUSSIBERAD) bersama CODEPOLITAN ini mengangkat kebutuhan pengamanan IT/OT TNI AD dan membuka kategori Defensive Shield (Penangkalan) (Kartika Cyber Hackathon, 2026). Proposal ini masuk pada kategori tersebut dengan fokus pada peringatan dini, bukan pada tindakan ofensif.

### 1.2 Rumusan Masalah

Berdasarkan latar belakang di atas, ada empat pertanyaan yang harus dijawab.

1. Bagaimana mendeteksi pergerakan penyusup di dalam jaringan dengan sinyal yang berkeyakinan tinggi dan volume alert yang terkendali?
2. Bagaimana menyatukan umpan IT dan OT dalam satu model korelasi, tanpa mengklaim bahwa setiap sentuhan otomatis merupakan serangan?
3. Bagaimana menghasilkan bukti yang cukup untuk investigasi dan pemetaan MITRE ATT&CK, bukan sekadar notifikasi?
4. Bagaimana menjalankan seluruh sistem secara on-prem di jaringan air-gap dengan biaya infrastruktur yang rendah?

### 1.3 Tujuan dan Sasaran

Tujuan proposal ini adalah merancang POLARIS, sistem peringatan dini berbasis deception untuk jaringan IT/OT, serta menyusun rencana implementasi dan evaluasinya. Sasaran yang hendak dicapai sampai batas waktu submission adalah:

- agent ringan yang menanam dan memantau umpan port, berkas, kredensial, URL, jalur web, serta decoy OT;
- collector dan detection engine yang memvalidasi event, melakukan korelasi, dan memetakan teknik MITRE;
- dashboard live dan kanal alert Telegram/webhook;
- installer satu baris dan paket dokumentasi teknis;
- video demo purwarupa dan slide presentasi.

### 1.4 Ruang Lingkup dan Batas Awal

Ruang lingkup proposal mencakup decoy port SSH, MySQL, Redis, dan RDP; honeytoken file; canary credential; honeytoken URL; web decoy path; decoy Modbus/TCP; decoy HMI web; collector; detection engine; dashboard; alert; pemetaan MITRE ATT&CK Enterprise dan ICS; serta AI summarizer opsional.

Di luar ruang lingkup: tindakan pencegahan otomatis yang memblokir trafik secara default, packet capture penuh, kendali langsung atas perangkat OT nyata, deployment pada jaringan operasional TNI AD, dan pengujian penetrasi formal. Auto-block dapat ditambahkan sebagai opsi, tetapi bukan bagian dari klaim proposal ini.

Dokumen ini adalah proposal solusi dan rencana pengembangan. Penulis belum menjalankan pengujian pada jaringan operasional dan tidak menyajikan angka kinerja sebagai hasil. Semua target evaluasi pada Bagian 5 diberi label sebagai target yang akan diukur.

### 1.5 Kontribusi

Kontribusi proposal ini bersifat rekayasa integrasi dan operasionalisasi, bukan penemuan konsep honeypot. Pertama, proposal merancang satu model data dan korelasi untuk umpan IT dan OT. Kedua, proposal menghubungkan event umpan dengan pemetaan MITRE yang membedakan aksi teramati dari teknik yang disimpulkan. Ketiga, proposal menyertakan model pengendalian false positive yang jujur, termasuk sumber false positive dari operasi sah. Keempat, proposal menyiapkan jalur deployment on-prem dan air-gap yang dapat diuji, bukan hanya arsitektur konseptual.

## 2. Tinjauan Pustaka dan Dasar Konsep

### 2.1 Deception Defense dan Honeypot

Honeypot adalah sumber daya yang sengaja dipasang untuk menarik interaksi tidak sah. Spitzner menempatkan honeypot sebagai alat untuk mengamati penyerang, bukan sebagai pengganti firewall atau IDS (Spitzner, 2002). Provos dan Holz memperluas gagasan itu ke honeypot virtual: layanan palsu yang dapat dijalankan pada satu host tanpa perangkat fisik tambahan (Provos & Holz, 2007). Keduanya menekankan hal yang sama: nilai honeypot bergantung pada seberapa meyakinkan umpan dan seberapa disiplin operator membaca interaksi.

Literatur yang lebih baru memetakan deception sebagai keluarga teknik, bukan satu alat. Han, Kheir, dan Balzarotti membagi deception berdasarkan mekanisme, target, dan tujuan, serta menunjukkan bahwa efektivitasnya sangat bergantung pada konteks penyebaran (Han et al., 2018). Pawlick, Colbert, dan Zhu menyusun taksonomi berbasis teori permainan dan menyoroti bahwa deception mengubah insentif penyerang: penyerang harus mengeluarkan biaya untuk memeriksa apakah yang ia temukan nyata atau umpan (Pawlick et al., 2019). Kedua kajian itu mendukung premis proposal ini, tetapi juga memberi peringatan: deception bukan deteksi universal, dan umpan yang mudah dikenali kehilangan nilainya.

### 2.2 Deteksi Deterministik dan Batasnya

Istilah “deterministik” dalam proposal ini merujuk pada pencatatan event, bukan pada vonis otomatis. Ketika sebuah koneksi masuk ke port umpan, sistem dapat memastikan bahwa koneksi itu terjadi. Sistem tidak dapat langsung memastikan bahwa pelakunya penyerang. Koneksi bisa berasal dari pemindai kerentanan tim biru, alat inventaris, atau administrator yang salah alamat. Karena itu, event umpan diberi tier kepercayaan dan dikorelasikan dengan konteks lain sebelum dinaikkan menjadi incident.

Pandangan ini sejalan dengan praktik pengendalian keamanan. NIST SP 800-53 Revisi kelima memuat SC-26 Decoys sebagai kontrol yang menempatkan komponen sebagai target serangan untuk mendeteksi, mengalihkan, dan menganalisis serangan (NIST, 2020). NIST SP 800-160 Vol. 2 Revisi 1 menempatkan deception dalam kerangka cyber resiliency: kemampuan sistem untuk mengantisipasi, menahan, pulih, dan beradaptasi terhadap gangguan (NIST, 2021).

Keduanya tidak menjanjikan deteksi tanpa kesalahan. Yang ditekankan adalah perencanaan, pengukuran, dan tata kelola.

Perbandingan yang lebih tepat bukan "deception versus IDS", melainkan "deception sebagai lapisan sinyal tinggi di samping IDS/SIEM". IDS berbasis anomali berguna untuk cakupan luas; deception berguna untuk interaksi yang seharusnya tidak terjadi. Kombinasi keduanya memberi analis dua sudut pandang: pola trafik yang menyimpang, dan sentuhan pada umpan yang tidak memiliki alasan sah.

### 2.3 MITRE ATT&CK sebagai Bahasa Pemetaan

MITRE ATT&CK menyediakan kosakata teknik penyerang yang dapat dipakai bersama oleh tim deteksi, tim respons, dan pengambil keputusan (MITRE Corporation, n.d.-a). Untuk lingkungan OT, ATT&CK for ICS menyediakan teknik yang berbeda dari versi Enterprise (MITRE Corporation, n.d.-b). Pemetaan berguna untuk tiga hal: menjelaskan incident kepada pihak nonteknis, mengukur cakupan deteksi, dan menghubungkan event dengan playbook respons.

Pemetaan juga mudah disalahgunakan. Menempelkan label teknik pada setiap event membuat laporan terlihat lengkap tanpa benar-benar menambah pemahaman. Proposal ini karena itu membedakan tiga tingkat: aksi yang teramati langsung (misalnya koneksi ke port umpan), teknik yang diindikasikan (misalnya Network Service Discovery), dan teknik yang hanya berpotensi (misalnya Remote Services: Remote Desktop Protocol ketika belum ada autentikasi). Pemetaan dilakukan secara konservatif, dan daftar lengkap beserta tingkat keyakinannya tersedia di Lampiran A.

### 2.4 Posisi POLARIS

POLARIS tidak menggantikan IDS, SIEM, atau EDR. Ia menambahkan lapisan yang lebih sempit tetapi lebih tegas: interaksi dengan umpan. Kelebihan yang diklaim bukan "deteksi semua serangan", melainkan "sinyal awal yang sulit diabaikan ketika seseorang menyentuh sesuatu yang tidak seharusnya". Kelemahan yang diakui adalah cakupan yang bergantung pada penempatan umpan, kemungkinan umpan dikenali, dan kebutuhan disiplin operasional agar umpan tidak tersentuh aktivitas sah.

Dengan posisi itu, POLARIS cocok dipakai sebagai pelengkap di lingkungan yang membutuhkan sinyal tinggi dan tidak dapat bergantung pada layanan cloud. Ia paling berguna pada tahap awal rantai serangan: reconnaissance, percobaan kredensial, dan pergerakan lateral awal. Ia tidak dirancang untuk menggantikan sensor OT pasif atau sistem kontrol industri.

## 3. Solusi yang Diusulkan

### 3.1 Gambaran Umum

POLARIS adalah sistem peringatan dini yang bekerja dengan cara menunggu, bukan menebak. Pada setiap node target, agent menanam beberapa jenis umpan: port layanan palsu, berkas yang tampak berisi kredensial, token tanpa akses nyata, URL penanda, jalur web yang hanya menarik bagi pemindai, serta layanan OT palsu. Umpan tersebut tidak dipakai aplikasi produksi. Ketika ada pihak yang menyentuhnya, agent mencatat peristiwa dan mengirimkannya ke collector.

Collector memvalidasi event, menyimpannya, dan meneruskannya ke detection engine. Engine menebak alat yang mungkin dipakai, mengelompokkan event dari sumber yang sama dalam jendela waktu, menghitung keparahan, dan memetakan teknik MITRE. Hasilnya bukan daftar alert mentah, melainkan incident dengan ringkasan, timeline, bukti, dan tingkat keyakinan.

### 3.2 Prinsip Desain

Tujuh prinsip berikut menjadi batas rancangan sekaligus alat untuk menolak fitur yang tidak perlu.

1. **Umpan tidak boleh menyentuh operasi normal.** Setiap umpan dievaluasi terhadap kemungkinan backup, antivirus, alat konfigurasi, dan pemindaian rutin. Jika ragu, tier diturunkan atau umpan tidak dipasang.
2. **Deterministik lebih dulu, heuristik kemudian.** Event umpan dicatat apa adanya. Fingerprinting dan skor severity adalah lapisan tambahan, bukan pengganti bukti.
3. **Disiplin bukti.** Setiap incident menyimpan waktu, sumber, jenis event, potongan payload yang relevan, dan hash bukti.
4. **On-prem dan air-gap lebih dulu.** Tidak ada ketergantungan wajib pada cloud, API eksternal, atau threat intelligence berbayar.
5. **Hak akses minimal dan tidak destruktif.** Agent tidak mengubah data produksi, tidak menjalankan payload penyerang, dan tidak memberikan akses nyata melalui kredensial umpan.
6. **Deploy satu baris, overhead rendah.** Agent berupa satu binary, collector berjalan sebagai satu layanan, dan database embedded.
7. **Klaim jujur dan terukur.** False positive tidak diklaim nol. Setiap target kinerja diberi label dan diuji pada lingkungan terkontrol.

### 3.3 Komponen Sistem

POLARIS terdiri dari enam komponen yang dapat dijalankan pada satu mesin untuk demo atau dipisahkan pada deployment produksi.

- **Agent** ditulis dalam Go sebagai satu binary statis. Agent membuka listener decoy port, memantau honeytoken file, menyediakan web decoy path, mengelola honeytoken URL dan canary credential, menjalankan decoy Modbus/HMI, serta mengirim event ke collector dengan buffer lokal.
- **Collector** berbasis FastAPI menerima event melalui `POST /ingest`, memvalidasi payload, membatasi laju, menyimpan ke SQLite, dan menyediakan endpoint `GET /beacon/{token}` untuk honeytoken URL.
- **Detection engine** berjalan di Python dan menangani fingerprinting, korelasi, pemetaan MITRE, perhitungan severity, serta AI summarizer opsional.
- **Dashboard** menampilkan live feed melalui WebSocket, kartu incident, profil penyerang, timeline, dan bukti.
- **Kanal alert** mengirim notifikasi ke Telegram, webhook generik, atau Discord opsional.
- **Installer** menyediakan pemasangan satu baris dan paket offline untuk jaringan air-gap.

### 3.4 Alur Kerja

Alur data POLARIS dibuat sederhana agar mudah diaudit.

1. Penyerang atau alat otomatis menyentuh umpan: koneksi ke port, pembacaan berkas, permintaan ke jalur web, penggunaan kredensial, atau interaksi dengan decoy OT.
2. Agent menangkap event beserta metadata: waktu, alamat IP sumber, port, potongan payload, durasi koneksi, dan identitas agent.
3. Agent mengirim event ke collector. Jika collector tidak tersedia, event disimpan di buffer lokal dan dikirim ulang dengan backoff.
4. Collector memvalidasi event, menyimpannya ke SQLite, dan meneruskannya ke detection engine.
5. Engine melakukan fingerprinting, mencari incident yang cocok, menghitung severity, dan memetakan teknik MITRE.
6. Incident muncul di dashboard dan dikirim ke kanal alert.
7. Bukti disimpan untuk investigasi. AI summarizer opsional menambahkan narasi, tetapi tidak mengubah keputusan deteksi.

### 3.5 Taksonomi Umpan dan Tier Kepercayaan

Setiap umpan memiliki tingkat keyakinan yang berbeda. Honeytoken file yang dibaca oleh proses tak dikenal lebih kuat daripada satu koneksi ke port yang mungkin berasal dari pemindai. Karena itu, POLARIS memakai tiga tier.

**Tabel 1** Taksonomi umpan dan tier kepercayaan

| Tier | Umpan | Sinyal yang dicatat | MITRE | Severity |
|---|---|---|---|---|
| T1 | Honeytoken file | Pembukaan atau pembacaan berkas, proses, hash | T1552.001 / T1005 | High |
| T1 | Canary credential | Penggunaan kredensial pada layanan umpan | T1078 / T1552 | Critical |
| T1 | Honeytoken URL | Callback ke `/beacon/{token}` | T1595 / T1190 | High |
| T1 | OTP umpan | Penggunaan OTP dari IP tak dikenal | T1078 | Critical |
| T2 | Decoy port | Koneksi, payload awal, durasi | T1046 | Medium–High |
| T2 | Web decoy path | Request ke `/.env`, `/.git/config`, `/wp-admin` | T1595 | Medium |
| T2 | Decoy login | Percobaan autentikasi, username, password | T1110 | High |
| T2 | Decoy OT/ICS | Koneksi Modbus/HMI, function code | T0886 / T0831 | High |
| T3 | Korelasi multi-umpan | Kombinasi event satu IP dalam window | multi | Critical |

*Catatan.* Tier adalah tingkat keyakinan desain, bukan vonis. Severity final dihitung oleh engine dengan konteks tambahan.

### 3.6 Deteksi, Korelasi, dan Severity

Fingerprinting bertujuan memberi konteks, bukan memberi vonis. Sinyal yang dipakai meliputi urutan port yang disentuh, jarak waktu antar-koneksi, byte pertama yang dikirim, interaksi dengan banner, User-Agent pada web decoy, dan opsional fingerprint TLS seperti JA3/JA4. Dari sinyal itu, engine dapat memberi label seperti "indikasi nmap", "indikasi masscan", "indikasi hydra", atau "unknown scanner". Jika bukti tidak cukup, label "unknown" lebih baik daripada tebakan yang salah.

Korelasi memakai alamat IP sumber sebagai dimensi utama, jendela waktu 15 menit sebagai batas pengelompokan, dan urutan kill-chain sebagai pengikat. Contoh ilustratif: satu IP menghubungi 12 decoy port, mengakses tiga web decoy, lalu mencoba autentikasi ke decoy SSH dalam empat menit. Tiga jenis event itu digabung menjadi satu incident dengan severity tinggi. Contoh ini bukan hasil pengukuran, melainkan gambaran cara kerja.

Severity dihitung dari bobot tier, jenis umpan, variasi umpan yang tersentuh, dan kecepatan interaksi. Ambang batas ditulis di konfigurasi dan dicatat di log agar dapat diaudit. Canary credential yang dipakai dan decoy OT yang menerima percobaan write mendapat override ke level Critical atau High. Keputusan akhir tetap menyertakan alasan, bukan hanya angka.

Setiap incident menyimpan timeline event, alamat IP sumber, potongan payload yang relevan (diredaksi bila perlu), dugaan alat beserta tingkat keyakinan, daftar teknik MITRE, dan hash bukti. Bukti inilah yang membedakan incident dari notifikasi singkat.

### 3.7 Pemetaan MITRE ATT&CK

POLARIS memakai ATT&CK Enterprise untuk event IT dan ATT&CK for ICS untuk event OT (MITRE Corporation, n.d.-a,n). Pemetaan tidak dilakukan dengan menempelkan satu label pada setiap event. Ada tiga tingkat yang dibedakan: aksi yang teramati langsung, teknik yang diindikasikan, dan teknik yang hanya berpotensi.

Contohnya, koneksi ke 12 decoy port dalam waktu singkat diindikasikan sebagai Network Service Discovery (T1046). Sebaliknya, satu koneksi ke decoy RDP belum cukup untuk menyimpulkan Remote Services: RDP (T1021.001); yang teramati baru percobaan koneksi, bukan pergerakan lateral yang berhasil. Pada event OT, percobaan write ke register Modbus dapat diindikasikan sebagai Manipulation of Control (T0831) atau Modify Parameter (T0836), tetapi sistem tidak mengklaim bahwa proses fisik benar-benar berubah.

Pendekatan bertingkat ini penting untuk kredibilitas. Ia mencegah laporan incident yang terlihat lengkap tetapi menyesatkan. Teknik yang tidak didukung bukti tidak dimasukkan. Daftar pemetaan lengkap disajikan di Lampiran A.

### 3.8 Dukungan OT/ICS

OT menjadi pembeda penting dalam proposal ini. Serangan terhadap OT tidak berhenti pada data; ia dapat memengaruhi proses fisik. Panduan NIST SP 800-82 Revisi 3 menempatkan keamanan OT sebagai masalah yang berbeda dari IT karena prioritas availability, siklus hidup perangkat yang panjang, dan keterbatasan patch (NIST, 2023). POLARIS tidak mencoba mengendalikan perangkat OT. Ia menempatkan simulasi protokol sebagai umpan dan mencatat siapa yang berinteraksi dengannya.

Protokol yang dipertimbangkan adalah Modbus/TCP (502), S7comm (102), DNP3 (20000), EtherNet/IP (44818), BACnet (47808), IEC 60870-5-104 (2404), dan OPC UA (4840). Untuk MVP, Modbus/TCP dipilih karena paling sederhana dan paling ikonik. Decoy Modbus membalas function code dasar dengan register palsu, mencatat unit ID, alamat register, dan function code yang diminta. Percobaan write diperlakukan sebagai sinyal berisiko tinggi, meskipun tidak ada proses fisik yang terhubung.

Decoy HMI web melengkapi skenario OT. Halaman login dan dashboard palsu mencatat akses, percobaan login, dan kredensial yang dicoba. Kombinasi decoy Modbus dan decoy HMI memberi gambaran yang lebih meyakinkan daripada satu port terbuka.

Batasnya perlu dinyatakan. Decoy OT bukan pengganti sensor OT pasif seperti SPAN atau TAP. Ia paling tepat ditempatkan di segmen OT atau di jembatan IT/OT, bukan di host yang jelas-jelas merupakan server administratif. Nilainya adalah peringatan dini bahwa ada pihak tak sah menyentuh protokol industri, bukan visibilitas penuh atas proses industri.

### 3.9 AI Summarizer dengan Batas Peran

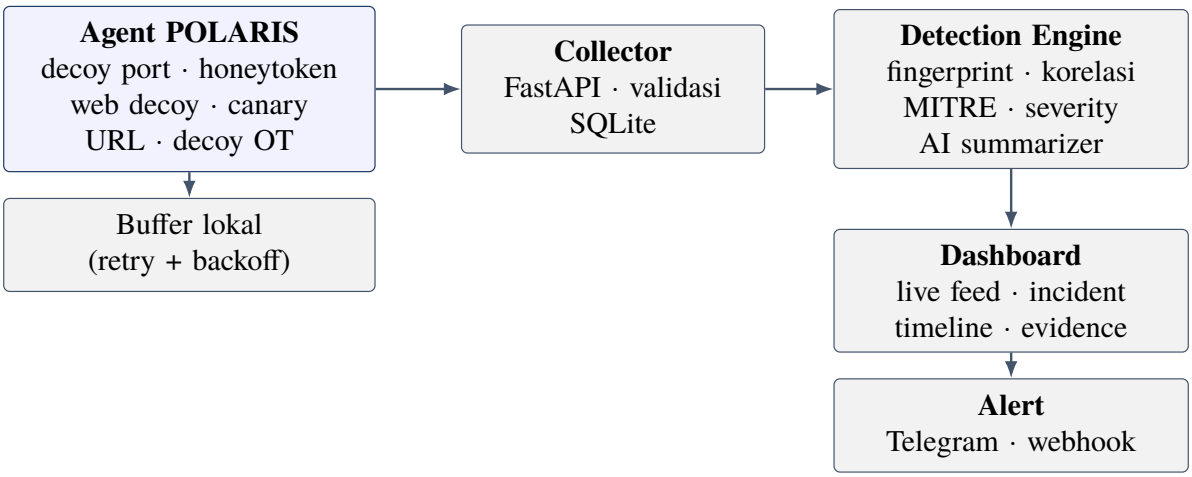
POLARIS menyediakan AI summarizer sebagai fitur opsional. Masukannya adalah data incident yang sudah terstruktur: alamat IP, jenis event, dugaan alat, teknik MITRE, dan timeline. Keluarannya berupa dua sampai empat kalimat Bahasa Indonesia yang menjelaskan apa yang terjadi dan mengapa perlu diperiksa.

Batas perannya tegas. AI tidak menentukan apakah suatu event berbahaya, tidak mengubah severity, dan tidak menambahkan fakta yang tidak ada di data. Keputusan deteksi tetap berada pada aturan dan korelasi yang dapat diaudit. Jika jaringan air-gap tidak mengizinkan

API eksternal, POLARIS memakai ringkasan berbasis template atau model lokal; sistem tetap berfungsi tanpa AI.

Pendekatan ini menjawab dua keberatan sekaligus. Bagi operator, ringkasan mempercepat pemahaman. Bagi auditor, keputusan tetap dapat dilacak ke event dan aturan, bukan ke keluaran model yang tidak deterministik.

## 4. Arsitektur Teknis




**Gambar 1** Arsitektur POLARIS: agent pada node target, collector, detection engine, dashboard, dan kanal alert.

### 4.1 Agent

Agent ditulis dalam Go dan dikompilasi menjadi satu binary statis. Pilihan ini memberi tiga keuntungan: tidak ada dependensi runtime di server target, cross-compile ke Linux/Windows/ARM mudah, dan goroutine cukup ringan untuk menjalankan beberapa listener sekaligus.

Modul agent dipisahkan berdasarkan jenis umpan: `decoy/ports.go` untuk listener port, `decoy/files.go` untuk honeytoken file dan pemantauan filesystem, `decoy/web.go` untuk jalur web dan login palsu, serta `decoy/ot_modbus.go` untuk decoy Modbus/TCP. Modul `sender` mengirim event ke collector, sedangkan `buffer` menyimpan event sementara ketika collector tidak tersedia.

Agent berjalan dengan hak akses minimal. Port di atas 1024 dipakai secara default; jika sebuah decoy harus memakai port rendah, agent dapat diberi capability `CAP_NET_BIND_SERVICE` alih-alih root penuh. Agent tidak menulis ke data produksi dan tidak pernah menjalankan payload yang diterimanya.

Konfigurasi agent dibaca dari file dan environment. Setiap agent memiliki token sendiri untuk mengirim event. Buffer lokal memakai file append-only dengan batas ukuran dan retensi sehingga event tidak hilang saat collector down, tetapi juga tidak memenuhi disk tanpa kendali.

### 4.2 Collector dan Detection Engine

Collector adalah layanan FastAPI dengan tiga endpoint utama: `POST /ingest` untuk menerima event agent, `GET /beacon/{token}` untuk honeytoken URL, dan `WS /live` untuk stream ke dashboard. Pydantic memvalidasi payload, token per-agent mengautentikasi pengirim, dan pembatasan laju mencegah banjir event. Data disimpan di SQLite melalui `aiosqlite`; skema tabel mencakup event, incident, evidence, agent, dan audit log.

Detection engine berjalan sebagai modul Python di dalam collector atau sebagai proses terpisah. Modul `fingerprint.py` menebak alat penyerang, `correlate.py` membentuk incident, `mitre.py` memetakan teknik, `severity.py` menghitung skor, dan `summarize.py` menghasilkan narasi opsional. Pemisahan ini memudahkan pengujian unit dan penggantian komponen tanpa mengubah agent.

### 4.3 Dashboard dan Kanal Alert

Dashboard menampilkan live feed melalui WebSocket, kartu incident dengan severity dan teknik MITRE, profil penyerang, timeline, serta bukti. Tampilan utama dibuat sederhana agar dapat dibaca pada layar proyektor saat demo. Kanal alert mendukung Telegram Bot API dan webhook generik; Discord disediakan sebagai opsi. Untuk jaringan air-gap, alert dapat diarahkan ke webhook SOAR internal atau ditampilkan di dashboard lokal.

### 4.4 Model Deployment

Ada tiga model penyebaran. **Standalone** menempatkan agent, collector, dan dashboard pada satu mesin; cocok untuk demo dan satuan kecil. **Distributed** menempatkan banyak agent pada node berbeda dengan satu collector/engine pusat; cocok untuk jaringan satuan dengan beberapa server. **Air-gapped** menjalankan seluruh komponen tanpa internet, dengan paket installer offline dan alert melalui webhook internal atau dashboard lokal.

Instalasi dirancang satu baris: `curl -fsSL <url>/install.sh | bash`. Untuk air-gap, paket yang sama disediakan sebagai arsip offline. Agent dipasang sebagai layanan sistem, collector dijalankan sebagai service, dan konfigurasi disimpan di direktori terpisah dari data.

### 4.5 Keamanan Sistem

Setiap agent memiliki token sendiri. Collector memvalidasi skema payload, membatasi laju, dan menolak event dari token yang tidak dikenal. Kredensial umpan bersifat inert: tidak memberikan akses nyata dan tidak pernah dipakai untuk autentikasi ke sistem produksi. Agent tidak melakukan tindakan destruktif; auto-block hanya tersedia sebagai opsi yang harus diaktifkan secara eksplisit.

Bukti disimpan dengan hash SHA-256 dan timestamp yang disinkronkan melalui NTP. Payload yang berpotensi memuat data sensitif diredaksi sebelum disimpan. Kebijakan retensi dapat diatur agar disk tidak penuh dan data pribadi tidak tersimpan lebih lama daripada yang diperlukan.

### 4.6 Kinerja dan Skalabilitas

Agent tidak menyimpan state percakapan dengan collector sehingga dapat di-scale horizontal. Collector menyimpan state di SQLite untuk demo; untuk produksi, roadmap menyediakan PostgreSQL. Korelasi berbasis jendela waktu dapat dipartisi per satuan atau tenant. Target kinerja—latensi, overhead, dan throughput—diukur pada lingkungan uji dan dilaporkan apa adanya, bukan diasumsikan.

## 5. Metode Pengembangan dan Evaluasi

### 5.1 Pendekatan Pengembangan

Pengembangan memakai siklus prototipe iteratif dalam empat minggu: menetapkan kebutuhan, merancang, membangun, menguji, lalu mendokumentasikan. Setiap akhir minggu menghasilkan artefak yang dapat diuji, bukan hanya catatan desain. Prioritas diberikan pada jalur end-to-end lebih dulu—agent, collector, alert—sebelum memperluas jenis umpan.

### 5.2 Lingkungan Uji

Pengujian dilakukan di laboratorium terisolasi yang terdiri dari dua laptop atau mesin virtual: satu sebagai server target yang menjalankan agent, collector, dan dashboard; satu sebagai mesin penyerang yang menjalankan nmap, hydra, curl, dan klien Modbus. Kedua mesin terhubung melalui switch atau hotspot lokal tanpa akses internet. Snapshot VM disiapkan agar lingkungan dapat direset sebelum setiap skenario.

Tidak ada jaringan operasional TNI AD yang dipakai. Semua data yang dihasilkan adalah data sintetis dari skenario uji. Jika pengujian memerlukan kredensial, yang dipakai adalah kredensial umpan yang inert, bukan kredensial nyata.

### 5.3 Skenario Uji

Pengujian tidak hanya menjalankan serangan. Skenario baseline jinak sama pentingnya karena di situlah false positive muncul.

**Tabel 2** Skenario uji terkontrol

| Kode | Aksi | Hasil yang diharapkan |
|---|---|---|
| S0 | Backup, pembaruan paket, monitoring, dan pemindai kerentanan internal | Tidak ada incident Critical; setiap sentuhan yang tidak disengaja dicatat sebagai kandidat false positive |
| S1 | `nmap -sV` ke server target | Event T1046, fingerprint mengarah ke nmap atau unknown |
| S2 | `curl` ke `/.env`, `/.git/config`, `/wp-admin` | Event T1595, alert web decoy |
| S3 | `hydra` ke decoy SSH | Event T1110, alert brute force |
| S4 | Membaca `.env` dan `credentials.txt` umpan | Event T1552.001/T1005, severity High–Critical |
| S5 | Modbus read dan write ke decoy 502 | Event T0886/T0831, alert OT |
| S6 | S1–S3 dari satu IP dalam 15 menit | Satu incident terkorleasi, bukan tiga alert terpisah |

### 5.4 Metrik Evaluasi

**Tabel 3** Metrik evaluasi dan target awal

| Metrik | Definisi | Target awal |
|---|---|---|
| Latensi deteksi | Waktu dari event diterima sampai incident tampil atau alert terkirim | $< 5$ detik di LAN |
| Kelengkapan event | Persentase field wajib yang terisi | 100% field inti |
| False positive | Incident Critical/High pada skenario S0 | 0 Critical/High; kandidat lain didokumentasikan |
| Akurasi korelasi | S6 menghasilkan satu incident, bukan alert terpisah | Satu incident |
| Akurasi fingerprint | Top-1/top-3 tebakan alat | Top-3 untuk alat umum; "unknown" diizinkan |
| Overhead | CPU dan RSS agent saat idle dan saat scan | $< 5\%$ CPU; $< 100$ MB RSS |
| Waktu instalasi | Fresh VM sampai agent dan collector berjalan | $< 5$ menit |
| Kelengkapan bukti | Incident memiliki timeline, hash, dan MITRE | 100% incident |

*Catatan.* Semua angka adalah target awal yang akan diukur pada lingkungan uji. Tabel ini bukan laporan hasil.

### 5.5 Prosedur Analisis

Analisis dilakukan secara deskriptif. Setiap skenario dijalankan minimal tiga kali, lalu dicatat latensi, jumlah event, jumlah incident, dan kelengkapan bukti. Karena jumlah skenario kecil dan lingkungan bersifat laboratorium, hasilnya tidak digeneralisasi secara statistik ke jaringan operasional. Penyimpangan dari target dilaporkan sebagai temuan, bukan disembunyikan.

### 5.6 Etika dan Keamanan Pengujian

Pengujian hanya dilakukan pada laboratorium milik penulis. Tidak ada payload destruktif, eksploitasi nyata, atau penggunaan kredensial produksi. Jaringan uji diisolasi dari internet dan dari jaringan kampus atau kantor. Data yang dikumpulkan diminimalkan: event yang tidak diperlukan untuk evaluasi tidak disimpan. Jika pengujian menemukan kerentanan pada perangkat lunak pihak ketiga, temuan dilaporkan secara bertanggung jawab, bukan dipublikasikan tanpa koordinasi.

## 6. Relevansi dan Manfaat untuk TNI AD

### 6.1 Kebutuhan IT/OT

Satuan TNI AD mengoperasikan server administratif, layanan internal, dan—di beberapa titik—perangkat OT yang mendukung fasilitas, utilitas, atau komando. Serangan terhadap OT tidak selalu berdampak pada data; ia dapat mengganggu proses fisik. POLARIS menyentuh dua domain itu dengan satu model data: event dari port, berkas, kredensial, dan URL diperlakukan sama seperti event dari decoy Modbus atau HMI. Analis tidak perlu membuka dua sistem terpisah untuk melihat satu sumber yang sama.

### 6.2 Kesesuaian dengan Jaringan Air-Gap

Banyak solusi komersial mengandalkan cloud, langganan threat intelligence, atau konektivitas ke vendor. Di jaringan yang terisolasi, ketergantungan itu menjadi penghalang. POLARIS dirancang dengan dependensi minimal: agent Go, collector Python, SQLite, dan dashboard lokal. Tidak ada fitur inti yang memerlukan internet. AI summarizer bersifat opsional dan dapat diganti dengan template atau model lokal.

### 6.3 Pengurangan Beban Analis

POLARIS tidak menghapus IDS atau SIEM. Ia mengurangi salah satu sumber beban: alert mentah yang tidak memiliki konteks. Event dari umpan dikorelasikan menjadi incident sehingga analis menerima satu kartu yang berisi sumber, timeline, teknik, dan bukti. Jumlah alert yang lebih sedikit dengan kualitas konteks yang lebih tinggi memberi ruang bagi analis untuk menangani insiden yang benar-benar membutuhkan perhatian.

### 6.4 Kesiapan Forensik

Setiap incident menyimpan bukti sejak event pertama: timestamp, alamat IP, port, potongan payload, hash, dan teknik MITRE. Bukti ini belum menggantikan proses forensik formal, tetapi mengurangi pekerjaan awal saat investigasi dimulai. Untuk organisasi yang sering kekurangan log terpusat, kemampuan menyimpan bukti di titik umpan memiliki nilai praktis.

### 6.5 Roadmap Adopsi

Adopsi dapat dimulai dari satu server atau satu segmen laboratorium, lalu diperluas ke node lain tanpa mengubah arsitektur. Tahap berikutnya mencakup integrasi ke SIEM/SOAR, PostgreSQL untuk skala lebih besar, dan penambahan protokol OT. POLARIS tidak menuntut penggantian infrastruktur yang sudah ada; ia menambah lapisan sensor dan analitik di atasnya.

## 7. Kelayakan Implementasi

### 7.1 Stack dan Dependensi

Agent memakai Go dan pustaka `fsnotify` untuk pemantauan berkas. Collector dan engine memakai Python dengan `fastapi`, `uvicorn`, `pydantic`, `httpx`, dan `aiosqlite`. Dashboard memakai WebSocket dan JavaScript tanpa build tool berat. Database SQLite dipilih karena embedded, tanpa server terpisah, dan cocok untuk jaringan air-gap. Untuk skala lebih besar, roadmap menyediakan PostgreSQL.

### 7.2 Instalasi dan Operasi

Instalasi dirancang satu baris. Agent dipasang sebagai service, collector dijalankan sebagai layanan terpisah, dan konfigurasi disimpan di direktori yang mudah diaudit. Untuk jaringan tanpa internet, paket installer disediakan sebagai arsip offline. Operasi harian mencakup pe-

meriksaan health check, rotasi log, dan peninjauan incident. Tidak ada ketergantungan pada akun cloud atau lisensi pihak ketiga.

### 7.3 Sumber Daya

Agent berjalan sebagai satu proses dengan listener ringan. Target awal adalah overhead rendah saat idle dan tetap terkendali saat pemindaian; angka pastinya diukur pada evaluasi. Collector dapat berjalan pada satu vCPU dengan RAM terbatas untuk skala demo. Kebutuhan penyimpanan terutama ditentukan oleh retensi event dan bukti, yang dapat diatur.

### 7.4 Risiko Implementasi

Risiko utama bukan teknologi, melainkan penempatan umpan. Umpan yang diletakkan di lokasi yang sering tersentuh backup atau pemindai akan menghasilkan noise. Karena itu, instalasi menyertakan panduan penempatan, allowlist, dan daftar periksa sebelum umpan diaktifkan. Risiko lain adalah kurangnya waktu untuk menguji semua protokol OT; MVP dibatasi pada Modbus/TCP dan HMI web.

## 8. Inovasi Teknis

Kebaruan POLARIS tidak terletak pada penemuan honeypot. Honeypot sudah lama ada (Spitzner, 2002; Provos & Holz, 2007). Kebaruan yang diklaim bersifat rekayasa integrasi dan operasionalisasi, dan itu pun perlu diuji.

Pertama, POLARIS menyatukan enam vektor umpan—port, berkas, kredensial, URL, jalur web, dan OT—dalam satu model event. Kedua, event tidak berhenti sebagai alert mentah; ia dikorelasikan menjadi incident yang menjelaskan satu sumber dalam satu jendela waktu. Ketiga, fingerprinting memberi konteks tentang alat yang mungkin dipakai, dengan opsi "unknown" ketika bukti tidak cukup. Keempat, pemetaan MITRE memakai ATT&CK Enterprise dan ATT&CK for ICS sekaligus, dengan tingkat keyakinan yang dibedakan.

Kelima, sistem dirancang air-gap-first: tidak ada fitur inti yang bergantung pada internet. Keenam, AI summarizer ditempatkan sebagai lapisan kenyamanan operator, bukan pengambil keputusan. Ketujuh, proposal ini menyertakan model pengendalian false positive dan rencana evaluasi baseline jinak—sesuatu yang sering hilang dari klaim produk deception.

Dengan batasan itu, inovasi yang diajukan dapat diuji: apakah integrasi multi-vektor benar-benar mengurangi waktu analis, apakah korelasi menghasilkan incident yang lebih berguna daripada alert terpisah, dan apakah decoy OT memberi peringatan yang tidak diberikan sensor IT biasa.

## 9. Roadmap dan Rencana Kerja

Milestone W1 adalah titik kritis. Jika jalur end-to-end belum berjalan pada 3 November, ruang lingkup dipangkas: port, berkas, dan alert diprioritaskan; web decoy dan OT dipindahkan

**Tabel 4** Roadmap pengembangan sampai batas submission

| Fase | Tanggal | Keluaran utama | Kriteria selesai |
|---|---|---|---|
| W0 | 25–27 Okt | Proposal final, registrasi, webinar pembekalan 2 | Proposal siap submit; lingkungan uji siap |
| W1 | 28 Okt–3 Nov | Agent decoy SSH, honeytoken file, collector, alert Telegram | Satu event mengalir end-to-end dan alert terkirim |
| W2 | 4–10 Nov | Web decoy, canary credential, decoy Modbus/HMI, dashboard, korelasi | Demo penuh dapat dipamerkan |
| W3 | 11–15 Nov | Installer, dokumentasi, video demo, slide, submission | Submit sebelum 15 November |

ke tahap berikutnya. Keputusan go/no-go dicatat agar tim tidak mengejar fitur yang tidak dapat didemokan.

Risiko jadwal terutama berasal dari pemantauan berkas dan simulator OT. Untuk pemantauan berkas, fallback polling mtime disiapkan bila `fsnotify` bermasalah. Untuk OT, respons Modbus minimal—menerima koneksi, mencatat function code, membalas register palsu—sudah cukup untuk demo; protokol lain bersifat opsional.

## 10. Kesesuaian dengan Kriteria Penilaian

**Tabel 5** Pemetaan proposal ke kriteria penilaian

| Kriteria (bobot) | Bagian | Bukti yang diajukan |
|---|---|---|
| Relevansi dan Manfaat (25%) | 1, 6 | Umpan IT dan OT, air-gap, pengurangan beban analis, kesiapan forensik |
| Inovasi Teknis (25%) | 3, 8 | Enam vektor umpan, korelasi incident, fingerprinting, MITRE Enterprise dan ICS |
| Fungsionalitas Purwarupa (25%) | 4, 5, 9 | Jalur end-to-end, skenario uji, metrik, rencana demo |
| Kelayakan Implementasi (15%) | 7 | Binary Go, FastAPI, SQLite, installer satu baris, paket offline |
| Kualitas Dokumentasi (10%) | Seluruh dokumen | Arsitektur, metode evaluasi, batasan, lampiran teknis |

Proposal ini tidak mengklaim skor tertentu. Tabel di atas menunjukkan bagian yang menjawab setiap kriteria sehingga juri dapat menilai klaim dan buktinya secara langsung. Klaim yang tidak didukung pengukuran diberi label sebagai target atau rencana.

## 11. Batasan dan Ancaman Validitas

### 11.1 Sumber False Positive

Klaim “false positive rendah” hanya dapat dipertahankan jika sumber gangguannya disebut. Tabel 6 merangkum sumber yang paling mungkin dan kontrol yang disiapkan.

### 11.2 Keterbatasan Lain

**Evasi.** Penyerang berpengalaman dapat mengenali umpan dari banner, timing, atau lokasi. POLARIS mengurangi risiko itu melalui realisme, tetapi tidak menghilangkannya. Jika

**Tabel 6** Sumber false positive dan kontrol operasional

| Sumber | Contoh | Kontrol |
|---|---|---|
| Backup | Job membaca `.env` atau `credentials.txt` umpan | Allowlist proses/user, jadwal, tier lebih rendah |
| Antivirus/EDR | Pemindaian berkas umpan | Exclusion direktori umpan atau pencatatan low severity |
| Config management | Alat inventaris membaca konfigurasi | Allowlist, maintenance window |
| Vulnerability scanner | Scan port dan jalur web umpan | Daftarkan scanner, korelasi dengan jadwal pemindaian |
| Kesalahan admin | Membuka berkas atau port yang salah | Tier T2, konteks user, review manual |
| Monitoring agent | Akses berkas untuk metrik | Allowlist proses dan path |

umpan dikenali, interaksi pertama tetap tercatat; nilai deteksinya menurun, bukan nol.

**OT.** Decoy OT adalah simulasi protokol, bukan pengganti sensor OT pasif. Ia tidak melihat trafik yang tidak menuju umpan dan tidak mengendalikan perangkat nyata. Penempatan di segmen yang salah dapat menurunkan realisme.

**Generalisasi.** Pengujian dilakukan di laboratorium dengan skenario sintetis. Hasilnya tidak dapat langsung digeneralisasi ke jaringan operasional yang memiliki volume, latensi, dan kebiasaan pengguna berbeda.

**Kinerja.** Dokumen ini tidak menyajikan hasil pengukuran. Semua angka pada Tabel 3 adalah target yang akan diuji.

**AI.** Ringkasan AI dapat keliru atau terlalu umum. Karena itu, AI tidak mengambil keputusan dan setiap ringkasan harus dibaca bersama data incident.

**Legal dan etika.** Pemasangan umpan pada jaringan nyata memerlukan izin pemilik jaringan. Penelitian ini tidak melakukan pengujian pada jaringan TNI AD atau jaringan pihak lain tanpa izin.

## 12. Penutup

POLARIS tidak menjanjikan deteksi semua serangan. Ia menjanjikan hal yang lebih sempit tetapi dapat diuji: setiap interaksi dengan umpan yang tidak seharusnya terjadi akan tercatat, dikorelasikan, dan disertai bukti yang cukup untuk diperiksa. Pada jaringan yang menggabungkan IT dan OT, kemampuan itu mengisi celah yang sering tidak terjangkau oleh IDS berbasis anomali.

Proposal ini menyatakan batasnya secara terbuka. False positive tidak diklaim nol. Decoy OT bukan pengganti sensor OT pasif. Fingerprinting bersifat best-effort. Purwarupa belum diuji pada jaringan operasional. Yang diajukan adalah rancangan yang dapat dibangun, diuji, dan diaudit—bukan janji yang tidak dapat diverifikasi.

Langkah berikutnya adalah menyelesaikan MVP end-to-end pada W1, memperluas umpan dan korelasi pada W2, lalu menyiapkan installer, dokumentasi, video, dan slide pada W3. Jika dijalankan sesuai roadmap, POLARIS dapat didemokan sebagai sistem yang bekerja, bukan sekadar konsep.

## Pernyataan Orisinalitas dan Penggunaan Alat Bantu

Penulis menyatakan bahwa ide, rancangan teknis, dan keputusan dalam dokumen ini merupakan karya penulis. Alat bantu AI digunakan untuk menyunting bahasa, memeriksa konsistensi struktur, dan merapikan format. Seluruh klaim teknis, referensi, dan keputusan rancangan diverifikasi oleh penulis. Tidak ada data, hasil pengukuran, atau temuan yang dihasilkan oleh AI. Dokumen ini adalah proposal solusi dan rencana pengembangan; ia tidak menyajikan hasil pengujian yang belum dilakukan.

## Daftar Pustaka

Han, X., Kheir, N., & Balzarotti, D. (2018). Deception techniques in computer security: A research perspective. *ACM Computing Surveys*, *51*(4), 1–36. https://doi.org/10.1145/3214305

Pawlick, J., Colbert, E., & Zhu, Q. (2019). A game-theoretic taxonomy and survey of defensive deception for cybersecurity and privacy. *ACM Computing Surveys*, *52*(4), 1–28. https://doi.org/10.1145/3337772

Spitzner, L. (2002). *Honeypots: Tracking hackers*. Addison-Wesley.

Provos, N., & Holz, T. (2007). *Virtual honeypots: From botnet tracking to intrusion detection*. Addison-Wesley.

National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (NIST SP 800-53 Rev. 5). https://doi.org/10.6028/NIST.SP.800-53r5

National Institute of Standards and Technology. (2021). *Developing cyber-resilient systems: A systems security engineering approach* (NIST SP 800-160 Vol. 2 Rev. 1). https://doi.org/10.6028/NIST.SP.800-160v2r1

National Institute of Standards and Technology. (2023). *Guide to operational technology (OT) security* (NIST SP 800-82 Rev. 3). https://doi.org/10.6028/NIST.SP.800-82r3

MITRE Corporation. (n.d.-a). *MITRE ATT&CK*. Diakses 25 Oktober 2026, dari https://attack.mitre.org/

MITRE Corporation. (n.d.-b). *MITRE ATT&CK for Industrial Control Systems*. Diakses 25 Oktober 2026, dari https://attack.mitre.org/techniques/ics/

Kartika Cyber Hackathon. (2026). *Kartika Cyber Hackathon 2026*. https://kartikacyberhackathon.id/

## A. Pemetaan MITRE ATT&CK

Tabel 7 merangkum pemetaan yang digunakan engine. Kolom keyakinan menggambarkan kuatnya bukti terhadap teknik tersebut, bukan tingkat bahaya. Teknik bertanda ID dari ATT&CK for ICS ditulis dengan penanda ICS; sisanya berasal dari ATT&CK Enterprise. Event aktual dapat memicu satu atau beberapa baris sekaligus, dan hasil korelasi menyertakan alasan setiap label.

**Tabel 7** Pemetaan aksi teramati ke teknik MITRE ATT&CK

| Aksi teramati | Teknik | ID | Keyakinan |
|---|---|---|---|
| Koneksi berulang ke banyak decoy port dalam jendela singkat | Network Service Discovery | T1046 | Tinggi |
| Permintaan berulang ke jalur web decoy | Active Scanning | T1595 | Tinggi |
| Percobaan autentikasi berulang pada decoy login | Brute Force | T1110 | Tinggi |
| Pembacaan berkas honeytoken | Unsecured Credentials: Credentials In Files | T1552.001 | Sedang–Tinggi |
| Pembacaan berkas honeytoken | Data from Local System | T1005 | Sedang |
| Penggunaan canary credential pada layanan | Valid Accounts | T1078 | Tinggi |
| Permintaan ke URL honeytoken | Active Scanning / Exploit Public-Facing Application | T1595 / T1190 | Sedang |
| Penggunaan OTP umpan dari sumber tak dikenal | Valid Accounts | T1078 | Tinggi |
| Koneksi ke decoy Modbus/TCP | Remote Services (ICS) | T0886 | Sedang |
| Percobaan write register Modbus | Manipulation of Control / Modify Parameter (ICS) | T0831 / T0836 | Tinggi |
| Koneksi ke decoy RDP tanpa autentikasi | Remote Services: Remote Desktop Protocol | T1021.001 | Rendah |
| Gabungan beberapa jenis event dari satu IP | Kombinasi teknik sesuai event teramati | banyak | Tinggi |

*Catatan.* Keyakinan turun jika sumber terdaftar pada allowlist operasional, misalnya pemindai kerentanan yang memiliki jadwal. Baris terakhir bukan teknik tunggal, melainkan hasil korelasi multi-umpan.

Tiga pengecualian perlu disebut. Pertama, satu koneksi tunggal ke satu port umpan tidak dianggap indikasi Network Service Discovery; pemetaan itu hanya diberikan pada pola multi-port. Kedua, percobaan autentikasi yang berhasil terhadap canary credential dipetakan Valid Accounts dengan keyakinan tinggi karena kredensial tersebut tidak memiliki akses sah. Ketiga, pada event OT, sistem tidak mengklaim bahwa proses industri benar-benar berubah; yang teramati adalah interaksi protokol pada umpan.

## B. Daftar Periksa Penempatan Umpan

Noise paling sering berasal dari penempatan umpan yang salah, bukan dari salahnya mesin deteksi. Daftar berikut dilalui sebelum umpan diaktifkan pada node produksi.

1. Inventarisasi aset di node yang dituju: layanan berjalan, pengguna yang aktif, dan jadwal operasi rutin.

2. Kumpulkan identitas sumber sah: akun job backup, host pemindai kerentanan, alat konfigurasi, dan agent monitoring.
3. Pastikan nama berkas dan nomor port umpan tidak dipakai layanan produksi dan tidak berada di jalur yang dibaca berulang oleh monitoring.
4. Terapkan allowlist pada collector berdasarkan identitas pada butir kedua, bukan hanya berdasarkan alamat IP.
5. Gunakan port di atas 1024 secara default; gunakan port rendah hanya dengan capability yang didokumentasikan.
6. Jalankan skenario baseline jinak (S0) satu siklus penuh sebelum alert Critical diaktifkan, lalu tinjau kandidat false positive yang muncul.
7. Catat di registry umpan: pemilik, tujuan, tier, tanggal pemasangan, dan masa tinjau ulang.
8. Tinjau ulang secara berkala: hapus umpan yang tidak lagi relevan dan perbarui allowlist ketika episode, aplikasi, atau peralatan berubah.

Registry umpan disimpan bersama konfigurasi agent dan ikut dalam paket instalasi ulang sehingga pemulihan node tidak meninggalkan umpan yang tidak terdokumentasi.